

Security+ 4.5 · Email Security

Mestre CyberSec — PDF baseado na aula do Professor Messer · 4.5 — Email Security (7:05) · [vídeo original](#)
[↗](#) · [YouTube](#) [↗](#)

SPF (lista de IP autorizado), DKIM (assinatura da mensagem), DMARC (política: o que fazer se falhar — reject/quarantine + notifica o dono). Gateway security antispam/antivirus. Encryption: S/MIME, PGP. Sem DMARC qualquer um impersona o domínio.

Highlights que a prova cobra

- SPF: lista os IP autorizado; DKIM: assina o corpo
- DMARC: a política — reject/quarantine quando falha; protege contra spoof

Dicas de prova

- 'email spoofing prevented by which combination of protocols'=SPF+DKIM+DMARC

Cenário clássico: 'email do CEO que na real veio de outro dominio'=spoof — DMARC teria bloqueado.

Perguntas de treino (10 questões)

Gabarito no fim. Tenta responder SEM olhar.

1. Um golpista manda e-mail SE PASSANDO pelo CEO e ordena que o financeiro faça uma transferência urgente. Que ataque é esse?

- A) BEC / CEO fraud (fraude do CEO)
- B) Whaling
- C) Vishing
- D) Tailgating

2. Um funcionário recebe ligação de alguém se passando por suporte técnico solicitando senha para 'atualização do sistema'. Que técnica é essa?

- A)** Vishing
- B)** Pretexting
- C)** Baiting
- D)** Tailgating

3. Cenário corporativo (Email Security): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.5), um analista avalia o seguinte requisito técnico: 'SPF: lista os IP autorizado; DKIM: assina o corpo'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: SPF: lista os IP autorizado; DKIM: assina o corpo...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

4. Cenário corporativo (Email Security): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.5), um analista avalia o seguinte requisito técnico: 'DMARC: a política — reject/quarantine quando falha; protege contra spoof'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: DMARC: a política — reject/quarantine quando falha; protege contra spoof...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

5. Cenário corporativo (Email Security): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.5), um analista avalia o seguinte requisito técnico: 'email spoofing prevented by which combination of protocols'=SPF+DKIM+DMARC'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'email spoofing prevented by which combination of protocols'=SPF+DKIM+DMARC...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

6. Cenário corporativo (Email Security): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.5), um analista avalia o seguinte requisito técnico: 'email do CEO que na real veio de outro dominio'=spoof — DMARC teria bloqueado.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: 'email do CEO que na real veio de outro dominio'=spoof — DMARC teria bloque...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

7. Cenário corporativo (Email Security): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.5), um analista avalia o seguinte requisito técnico: 'SPF: lista os IP autorizado; DKIM: assina o corpo'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: SPF: lista os IP autorizado; DKIM: assina o corpo...

8. Cenário corporativo (Email Security): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.5), um analista avalia o seguinte requisito técnico: 'DMARC: a política — reject/quarantine quando falha; protege contra spoof'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: DMARC: a política — reject/quarantine quando falha; protege contra spoof...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

9. Cenário corporativo (Email Security): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.5), um analista avalia o seguinte requisito técnico: 'email spoofing prevented by which combination of protocols'=SPF+DKIM+DMARC'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: 'email spoofing prevented by which combination of protocols'=SPF+DKIM+DMARC...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

10. Cenário corporativo (Email Security): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.5), um analista avalia o seguinte requisito técnico: 'email do CEO que na real veio de outro domínio'=spoof — DMARC teria bloqueado.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 'email do CEO que na real veio de outro domínio'=spoof — DMARC teria bloque...

GABARITO COMENTADO

- 1) A — BEC / CEO fraud (fraude do CEO).** BEC (Business Email Compromise) / CEO fraud: o atacante FINGE ser o executivo pra enganar um funcionário e extrair dinheiro/dados. Pegadinha do SY0-701: WHALING é o contrário — phishing MIRADO no executivo (ele é a vítima)
- 2) A — Vishing.** Vishing = phishing por VOZ/telefone (a 'ligação' é a chave). O golpista finge ser o suporte pra extrair a senha. (Pretexting é a técnica do cenário inventado, muitas vezes usada JUNTO com o vishing.)
- 3) B — Implementar a solução correspondente: SPF: lista os IP autorizado; DKIM: assina .** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.5 (Email Security): SPF: lista os IP autorizado; DKIM: assina o corpo. As demais alternativas configuram violações graves de conformidade
- 4) B — Implementar a solução correspondente: DMARC: a política — reject/quarantine quan.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.5 (Email Security): DMARC: a política — reject/quarantine quando falha; protege contra spoof. As demais alternativas configuram violações
- 5) B — Implementar a solução correspondente: 'email spoofing prevented by which combina.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.5 (Email Security): 'email spoofing prevented by which combination of protocols'=SPF+DKIM+DMARC. As demais alternativas configuram violação
- 6) C — Implementar a solução correspondente: 'email do CEO que na real veio de outro do.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.5 (Email Security): 'email do CEO que na real veio de outro dominio'=spoof — DMARC teria bloqueado.. As demais alternativas configuram vio
- 7) D — Implementar a solução correspondente: SPF: lista os IP autorizado; DKIM: assina .** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.5 (Email Security): SPF: lista os IP autorizado; DKIM: assina o corpo. As demais alternativas configuram violações graves de conformidade
- 8) A — Implementar a solução correspondente: DMARC: a política — reject/quarantine quan.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.5 (Email Security): DMARC: a política — reject/quarantine quando falha; protege contra spoof. As demais alternativas configuram violações
- 9) A — Implementar a solução correspondente: 'email spoofing prevented by which combina.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.5 (Email Security): 'email spoofing prevented by which combination of protocols'=SPF+DKIM+DMARC. As demais alternativas configuram violação
- 10) D — Implementar a solução correspondente: 'email do CEO que na real veio de outro do.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.5 (Email Security): 'email do CEO que na real veio de outro dominio'=spoof — DMARC teria bloqueado.. As demais alternativas configuram vio

